

NETSECURE ASSESS

Defensive Network Security & Governance Workspace
Comprehensive System Specification & Security Report

DOCUMENT CONTROL & METADATA

Target Project:	Campus Lab Baseline
Approved Scope:	10.20.0.0/24
Date Generated:	August 07, 2026 - 18:20 UTC
Classification:	CONFIDENTIAL - EDUCATIONAL DEFENSIVE REPORT
Document Version:	v1.0 (Full Technical Report)
Author:	NetSecure Lead Security Architect
Primary Platform:	FastAPI + React 19 + SQLAlchemy

Strictly Authorized Defensive Use Only. No Exploitation Features Contained.
NetSecure Assess Laboratory Baseline | Educational Security Workspace

Chapter 0: Table of Contents & Document Control

Document Table of Contents

Chapter 1: Executive Summary & Project Baseline Scope	Page 3
Chapter 2: Product Requirements & User Role Matrix	Page 4
Chapter 3: System Architecture & Technology Stack Breakdown	Page 5
Chapter 4: Bounded TCP-Connect Scanner & Target Safety Rules	Page 6
Chapter 5: Database Schema & Entity Relationship Model	Page 7
Chapter 6: REST API Specifications & OpenAPI Endpoints	Page 8
Chapter 7: Discovered Asset Inventory & Host Profiling	Page 9
Chapter 8: Vulnerability Findings & 0-100 Risk Scoring Model	Page 10
Chapter 9: Governance Control Assessment & 14-Control Posture	Page 11
Chapter 10: Traffic Metadata Analysis & Intrusion Detection Rules	Page 12
Chapter 11: Threat Model, Trust Boundaries & Security Countermeasures	Page 13
Chapter 12: Containerization Deployment & Production Hardening	Page 14
Chapter 13: Verification Test Suite, E2E Smoke Tests & Operations	Page 15

Revision History & Review Sign-offs

Rev	Date	Author	Summary of Changes
v0.1	2026-07-01	Security Team	Initial assessment protocol & project scope draft.
v0.5	2026-07-15	Engineering	Backend scanning engine and SQLite schema implementation.
v0.9	2026-08-01	QA & Auditor	Threat model verification and NIST CSF control mapping.
v1.0	2026-08-07	Lead Architect	Final comprehensive 15-page baseline snapshot report.

Chapter 1: Executive Summary & Project Baseline Scope

NetSecure Assess is a full-stack educational network-security workspace designed for university students, security researchers, and system administrators. It combines safe asset discovery, configuration findings management, privacy-preserving traffic metadata, explainable defensive alerts, governance control assessments, transparent risk scores, and exportable executive reports.

The product is strictly designed for authorized, defensive laboratory work. It intentionally omits exploitation, credential attacks, malware, denial-of-service, persistence, evasion, spoofing, or data-exfiltration features. All findings are non-intrusive hypotheses that require human validation.

Executive Security Metrics Summary

OVERALL RISK	ASSETS SCANNED	OPEN FINDINGS	MATURITY INDEX
51.0 / 100	4 Active	4 Issue(s)	2.89 / 5.0

Active Assessment Project Overview

Project Name: Campus Lab Baseline

Description: Authorized training VLAN baseline and remediation exercise.

Authorized Scope: 10.20.0.0/24 | Timeline: 2026-07-08 to 2026-10-06

Key Takeaways:

- Baseline risk is elevated due to cleartext services (Telnet/HTTP) and accessible internal services.
- All target hosts belong to authorized private laboratory networks (RFC1918 10.20.0.0/24).
- Remediation tasks have been automatically generated for high and medium severity observations.

Chapter 2: Product Requirements & User Role Matrix

NetSecure Assess enforces strict role-based access control (RBAC) to ensure that administrative, analytical, and educational functions remain segregated per organizational hierarchy.

User Role Matrix & Authorization Permissions

Role	Default Account	Permitted Capabilities & System Scope
Administrator	admin@netsecure.local	Full system access, user management, global allowlists, audit log review, safety configuration.
Researcher	researcher@netsecure.l	Project creation, target scan execution, finding management, assessment completion, report generation.
Student	student@netsecure.loca	Read-only access to assigned projects, view findings, review remediation tasks, complete self-assessment.
Guest / Audited	N/A	Strictly prohibited from initiating scans or viewing sensitive asset metadata.

Core Functional & Non-Functional Requirements

1. Safety-First Target Parsing: Prevent inadvertent scanning of public internet targets via strict parsing.
2. Transparent Risk Formulas: Provide deterministic, explainable risk scores without hidden black-box metrics.
3. Privacy-Preserving Traffic Imports: Import connection metadata from PCAP files without retaining packet payloads.
4. Immutable Auditability: Log every authorization declaration, scan initiation, and report export.

Chapter 3: System Architecture & Technology Stack Breakdown

NetSecure Assess is built as a modular monolith. FastAPI routes handle transport validation and authorization, domain service modules own target safety, scanning, audit, and scoring logic, while SQLAlchemy manages persistence.

Technology Stack Specifications

Layer	Technology Selection	Technical Role & Implementation Detail
Frontend SPA	React 19 + TypeScript + Vite	Responsive UI, state management, interactive dashboards, dynamic risk charts.
API Transport	FastAPI (Python 3.12+)	REST endpoints, Pydantic v2 schemas, auto OpenAPI docs, JWT bearer auth.
Security Service	pwdlib [Argon2] + PyJWT	Argon2id password hashing, access/refresh token issue & rotation.
ORM Persistence	SQLAlchemy 2.0 + Alembic	Data mapping, transaction boundaries, schema migrations, cross-DB portability.
PDF Report Engine	fpdf2 2.8.4	Defensive report generation, vector layout rendering, table generation.
Database Storage	SQLite / PostgreSQL	SQLite for local demo mode (`netsecure.db`); PostgreSQL for Docker prod.

Directory Layout & Modular Monolith Organization

- backend/app/api: FastAPI APIRouter handlers for auth, assets, scans, findings, alerts, reports.
- backend/app/models: SQLAlchemy ORM entity definitions and database relationships.
- backend/app/services: Domain scanning engine, target normalizer, risk calculator, seed generator.
- frontend/src/components: Reusable UI cards, tables, navigation bars, modals, risk indicators.

Chapter 4: Bounded TCP-Connect Scanner & Target Safety Rules

Every scan requires an explicitly accepted authorization record storing user consent, purpose, approved scope, and policy acceptance before sockets are created. Target strings are parsed rather than interpolated into shell commands.

Defensive Scan Ceilings & Safety Limits

Parameter	Default Ceiling	Enforcement & Operational Safety Mechanism
Target Scope	Private IPv4 Only	Python ipaddress module validates RFC1918 private ranges & localhost.
CIDR Host Limit	64 Hosts Max	Rejects networks larger than /26 to prevent broadcast subnet overload.
Port Count Limit	256 Ports Max	Caps requested port ranges; prevents wide port sweeping.
Socket Concurrency	16 Sockets	Bounded async TCP connect worker prevents socket exhaustion.
Banner Byte Limit	Small Banner Read	Short-lived banner read; immediate socket close upon response.
Scan Budget Timeout	5 Minutes Hard Cap	Enforces hard deadline; checks cancellation between every host.

Target Normalization Logic

The normalization routine rejects link-local, multicast, unspecified, public IPv4, IPv6, malformed strings, and oversized CIDRs. Redirects do not expand scope. Scans are TCP connect checks only: no raw-packet stealth, evasion, credential brute-force, or payload injection is included.

Chapter 5: Database Schema & Entity Relationship Model

The database schema uses string UUID primary keys for portable demo data and cross-database compatibility. Foreign key constraints enforce project isolation across all domain records.

Core Database Entity Descriptions

Entity Name	Primary Keys & FKs	Key Attributes & Functional Purpose
User	id (UUID)	email, full_name, role, password_hash, failed_logins, locked_until.
Project	id (UUID), owner_id -> User	name, description, scope, start_date, end_date.
AuthorizationRecord	id, project_id, user_id	target, purpose, approved_scope, policy_accepted.
Asset	id, project_id -> Project	ip_address, hostname, probable_os, criticality, risk_score.
Service	id, asset_id -> Asset	port, name, product, version, tls (boolean).
Scan	id, project_id, user_id	target, profile, status, hosts_found, services_found.
Finding	id, asset_id, scan_id	title, severity, confidence, risk_score, remediation.
Assessment	id, template_id, user_id	name, status, score, maturity_score, residual_risk.
AuditLog	id, user_id -> User	action, entity_type, entity_id, details, source_ip.

Chapter 6: REST API Specifications & OpenAPI Endpoints

FastAPI automatically generates OpenAPI documentation available at /docs. Endpoint validation relies on Pydantic schemas with type enforcement and role authorization dependencies.

Primary API Route Directory

HTTP Method	Route Path	Min Role	Description & Operation
POST	/api/auth/token	Public	Authenticate user credentials; return access and refresh JWTs.
GET / POST	/api/projects	Student	List assigned projects or create a new authorization boundary.
GET / POST	/api/assets	Student	Retrieve asset inventory or register manual asset observations.
POST	/api/scans	Researcher	Validate scope, record authorization, launch bounded TCP scan.
GET / PATCH	/api/findings	Student	Query discovered findings; update remediation status.
POST	/api/traffic/import	Researcher	Upload PCAP file; parse connection metadata only.
GET / POST	/api/assessments	Student	Load NIST/CIS control templates and submit posture evaluations.
GET / POST	/api/reports	Researcher	Build executive or technical report snapshots in PDF/JSON/CSV.
GET	/api/audit-logs	Admin	Query append-only security audit log trail.

Chapter 7: Discovered Asset Inventory & Host Profiling

Discovered assets are profiled using passive TCP response analysis, banner parsing, and service identification. Criticality scores reflect business impact on a scale from 1 (Low) to 5 (Critical).

Assessed Host Inventory

IP Address	Hostname	Probable OS	Criticality	Calculated Risk Score
10.20.0.12	lab-web-01	Ubuntu Linux	Level 4	68.0 / 100 (High)
10.20.0.24	lab-db-01	Linux appliance	Level 5	42.0 / 100 (Elevated)
10.20.0.42	training-iot	Embedded Linux	Level 2	76.0 / 100 (High)
10.20.0.51	student-ws-04	Windows 11	Level 2	18.0 / 100 (Low)

Exposed Service Inventory

Host IP	Port	Service	Version / Product	Security Notes
10.20.0.12	22	ssh	OpenSSH (simulated)	Standard remote management.
10.20.0.12	80	http	Apache (simulated)	Missing Content-Security-Policy header.
10.20.0.12	443	https	Apache (TLS 1.3)	Secure HTTPS listener.
10.20.0.24	5432	postgresql	PostgreSQL 16	Unrestricted subnet access listener.
10.20.0.42	23	telnet	Legacy Telnet	Unencrypted administrative protocol.
10.20.0.51	445	smb	Windows SMB	Legacy SMB signing policy.

Chapter 8: Vulnerability Findings & 0-100 Risk Scoring Model

Finding risk is a 0-100 weighted result: Technical Severity (30%), Detection Confidence (10%), Asset Criticality (15%), Exposure (10%), Likelihood (10%), Business Impact (15%). Implemented controls reduce residual score.

Identified Vulnerabilities & Remediation Steps

Finding Title	Severity	Risk Score	Actionable Remediation Guidance
Cleartext Telnet service	HIGH	84.0 / 100	Disable Telnet and use SSH.
HTTP response missing Co	MEDIUM	55.0 / 100	Deploy and test a restrictive CSP.
Database listener access	MEDIUM	47.0 / 100	Restrict the database security group to application hos
Legacy SMB signing polic	LOW	24.0 / 100	Require SMB signing through the managed baseline.

Risk Rating Thresholds

- Low: 0 to 20 | Moderate: 21 to 40 | Elevated: 41 to 60 | High: 61 to 80 | Critical: 81 to 100
- All findings are advisory hypotheses requiring human verification before remediation.

Chapter 9: Governance Control Assessment & 14-Control Posture

Assessment scores assign 100% to implemented, 50% to partially implemented, and 0% to not implemented or unreviewed controls. Maturity index equals total score divided by 20 (scale 0.0 to 5.0). Residual risk equals 100 minus overall score.

14-Category Security Control Posture Evaluation

ID	Control Category	Implementation Status	Assessor Evidence & Review Notes
AM-01	Asset management	Implemented	Simulated evidence reviewed.
AC-01	Access control	Partially Implemented	Follow-up evidence needed.
AU-01	Authentication	Implemented	Simulated evidence reviewed.
NS-01	Network security	Partially Implemented	Follow-up evidence needed.
DP-01	Data protection	Implemented	Simulated evidence reviewed.
LM-01	Logging and monitoring	Partially Implemented	Follow-up evidence needed.
VM-01	Vulnerability management	Not Implemented	Follow-up evidence needed.
IR-01	Incident response	Partially Implemented	Follow-up evidence needed.
BR-01	Backup and recovery	Implemented	Simulated evidence reviewed.
SD-01	Secure software development	Not Reviewed	Follow-up evidence needed.
CS-01	Cloud security	Not Applicable	Follow-up evidence needed.
PS-01	Physical security	Implemented	Simulated evidence reviewed.
SA-01	Security awareness	Partially Implemented	Follow-up evidence needed.
TP-01	Third-party risk	Not Implemented	Follow-up evidence needed.

Chapter 10: Traffic Metadata Analysis & Intrusion Detection Rules

NetSecure Assess accepts PCAP/PCAPNG uploads but discards packet payloads, retaining only aggregated network metadata (source/destination IP, ports, protocol, packet counts, byte volumes).

Active Defensive Alerts Log

Rule Name	Severity	Source IP	Destination IP	Observed Evidence
Cleartext prot	HIGH	10.20.0.42	10.20.0.51	18 TCP connections to destination port 23
New service ob	MEDIUM	10.20.0.12	10.20.0.12	TCP/8080 was absent from the previous simu

Configured Detection Rules Engine

- Cleartext protocol observed: Flags TCP ports 21, 23, 80, 110, 143.
- Connection burst: Flags connection density exceeding 100 sockets per 60-second window.

Chapter 11: Threat Model, Trust Boundaries & Security Countermeasures

The product threat model addresses five primary trust boundaries to ensure defensive security and software integrity.

Trust Boundaries & Defensive Mitigations

Trust Boundary	Identified Threat Vector	Implemented Security Mitigation
Browser -> API	Token theft, XSS, CSRF	Short-lived JWTs, Argon2 password hashes, strict CORS origin matching.
API -> Database	Cross-project leak, SQLi	SQLAlchemy parameterized ORM queries, explicit project-id filters.
Worker -> Target	Scope bypass, DNS rebinding	ipaddress module normalization, DNS re-validation, host/port ceilings.
File Imports	Decompression bombs, path traversal	Metadata-only parser, byte limits, path sanitization.
Reports & Logs	Formula injection, audit tampering	CSV cell neutralization, append-only database audit log table.

Chapter 12: Containerization Deployment & Production Hardening

NetSecure Assess provides multi-container orchestration via Docker Compose. Production deployments must follow hardening guidelines.

Production Readiness Hardening Checklist

Category	Status	Required Hardening Control Action
Secret Management	Required	Replace default SECRET_KEY in .env with a 256-bit cryptographically secure string.
Mode Flag	Required	Set DEMO_MODE=false to remove development-only demo accounts.
TLS Termination	Required	Terminate TLS 1.3 at reverse proxy (Nginx / Caddy); restrict CORS origins exactly.
Worker Isolation	Required	Run scan workers in isolated network namespaces with egress allowlists.
Database Security	Required	Deploy PostgreSQL on encrypted volumes with automated daily backups.
Audit Centralization	Recommended	Export append-only audit logs to central SIEM / syslog collector.

Chapter 13: Verification Test Suite, E2E Smoke Tests & Operations

Automated backend tests verify target normalization safety, authorization boundaries, and risk scoring logic without touching external networks.

Test Suite Execution Commands

```
# Run backend unit and safety tests:
cd backend && pytest -q
# Run Playwright browser smoke test:
cd frontend && npm run test:e2e
```

Report Concluding Remarks

This 15-page report confirms that NetSecure Assess meets all non-offensive security requirements, enforced target bounds, and governance framework controls. Operational deployment within defensive educational laboratories is verified.